Secure Software Development Lifecycle (SSDLC) Standard

Policy ID: STD-SSDLC-006 | Version 1.0 | Classification: Internal

Policy Owner	CISO / Chief Technology Officer	**Effective Date**	12 September 2026
Review Cycle	At least annually and upon material legal, threat, technology, or business change	**Approval Authority**	Executive Risk / Information Security Governance Committee
Applies To	Enterprise workforce, controlled entities, and in-scope suppliers	**Control Status**	Mandatory unless formally excepted

Mandatory language: "MUST" and "MUST NOT" indicate mandatory requirements. "SHOULD" indicates an expected control that may be varied only when a risk-based alternative is documented. "Strictly Prohibited" identifies conduct that is not permitted absent an explicit, legally valid emergency or exception pathway.

1. Objective

This standard defines mandatory security activities for planning, designing, implementing, reviewing, testing, releasing, operating, and retiring software. Security is a release criterion and cannot be deferred solely because a feature deadline is at risk. The objective is to prevent avoidable vulnerabilities and make software risk visible, testable, and accountable throughout the lifecycle.

2. Scope

This standard applies to internally developed applications, services, APIs, libraries, scripts, infrastructure-as-code, mobile applications, desktop applications, firmware, data pipelines, AI applications, customer integrations, and material modifications to acquired software. It applies to production systems and to non-production systems that handle sensitive data or privileged credentials.

3. Governance, Accountability, and Roles

Engineering Leadership. Ensures teams have trained security champions, time for remediation, and compliant pipelines.

Developers. Implement secure designs and coding practices, review changes, fix vulnerabilities, and protect credentials.

Application Security. Defines gates, threat modeling methods, scanning baselines, and security testing.

Product Owners. Include security and privacy requirements in acceptance criteria and risk decisions.

Release Managers / SRE. Ensure approved artifacts, deployment controls, logging, rollback, and operational readiness.

4. Policy Rules and Mandatory Guidelines

- Each application MUST have a defined owner, risk classification, data classification, deployment inventory, dependency inventory, and security contact.
- New Internet-facing, high-risk, multi-tenant, authentication, payment, privileged-administration, or sensitive-data features MUST undergo threat modeling before implementation. Material architecture changes require threat-model update.
- Security requirements MUST be written as testable acceptance criteria. 'Use best practices' without concrete controls is insufficient for high-risk functionality.

- Code changes to protected branches MUST use peer review. Authors MUST NOT self-approve changes that alter authentication, authorization, cryptography, secrets, security logging, infrastructure guardrails, or release controls except under documented emergency procedures.
- Known critical vulnerabilities MUST NOT be released to production without formal risk acceptance. High-severity vulnerabilities require remediation within enterprise SLAs or documented exception with compensating controls.
- Debug endpoints, test credentials, sample admin accounts, development backdoors, hard-coded secrets, and verbose production error modes are Strictly Prohibited in production artifacts.
- Production code MUST fail securely. Authorization errors must deny access; cryptographic verification failures must reject data; security-control failures must not silently degrade to an insecure mode unless explicitly designed and approved.
- Input from users, APIs, files, queues, model outputs, third-party services, and environment variables MUST be treated as untrusted unless validated by a defined trust boundary.
- Security defects MUST be tracked in the approved issue system with severity, owner, due date, affected versions, and remediation evidence. Teams MUST NOT close findings merely because exploitability is inconvenient to reproduce if the underlying weakness remains.
- Unsupported frameworks, runtimes, operating systems, or dependencies MUST NOT remain in production without time-limited exception and migration plan.

5. Technical and Coding Constraints

- SAST MUST run on every protected-branch merge or equivalent CI event for supported languages. SCA/dependency scanning and secret scanning MUST run at least on merge and release. Critical findings MUST block release according to configured policy.
- DAST or equivalent dynamic/API security testing MUST be performed for Internet-facing applications at appropriate lifecycle stages. High-risk applications require periodic penetration testing by qualified independent personnel or teams.
- Passwords MUST NOT be stored with general cryptographic hashes such as MD5, SHA-1, SHA-256, or SHA-512 alone. Password verifiers MUST use an approved adaptive password hashing function such as Argon2id, scrypt, or bcrypt with enterprise-approved work factors and per-user salts.
- MD5 and SHA-1 MUST NOT be used for security-sensitive hashing, signatures, integrity, certificate signatures, or password storage. Their use for non-security checksums requires documented justification to avoid misuse.
- SQL queries MUST use parameterized statements or safe ORM mechanisms. String concatenation of untrusted input into SQL, LDAP, shell commands, or interpreter expressions is prohibited.
- Output encoding and templating protections MUST be context-appropriate to prevent cross-site scripting. Disabling framework escaping requires explicit review.
- Deserialization of untrusted native object formats that can instantiate arbitrary types or execute code is prohibited. Use constrained data formats and explicit schema validation.
- Memory-unsafe languages MAY be used where business requirements justify them, but high-risk parsing, cryptography, and network-facing components require bounds checking, fuzzing, sanitizers, or safer abstractions as applicable.
- CI/CD credentials MUST be short-lived or centrally managed, least-privileged, non-human identities. Build pipelines MUST NOT expose secrets to untrusted pull requests.
- Release artifacts SHOULD be signed or otherwise provenance-verifiable. Production deployments MUST reference immutable artifacts; rebuilding from an unpinned branch during deployment is prohibited.
- Security headers, cookie flags, CSRF controls, session expiration, MFA, and authorization MUST be implemented according to the application architecture and data risk. Session tokens MUST not appear in URLs.

- Security logging MUST cover authentication events, authorization failures, privilege changes, sensitive configuration changes, admin operations, and relevant high-risk business actions without logging secrets.

6. Operational Control Requirements

- Production releases MUST be traceable from deployed artifact to source commit, build pipeline, test results, approvals, SBOM, and change record.
- Security champions and developers working on high-risk systems MUST receive periodic secure-development training relevant to their technology stack.
- Post-release vulnerabilities and incidents MUST feed back into coding standards, tests, threat models, and reusable security controls so recurrence is reduced.

7. Monitoring, Assurance, and Records

Compliance with this policy MUST be demonstrable. Evidence is part of the control, not an optional administrative artifact. Records MUST be retained according to the enterprise records-retention schedule, legal holds, applicable regulation, and contractual requirements.

Minimum expected records:

- Threat models
- Security requirements
- Code-review evidence
- SAST/SCA/secret scan results
- DAST and penetration-test reports
- SBOMs
- Vulnerability tickets
- Release provenance
- Security exceptions

Security, Internal Audit, Privacy, Legal, Compliance, and authorized risk functions MAY request evidence and perform sampling or technical validation. System owners MUST provide accurate evidence and MUST NOT suppress, alter, or fabricate control records.

8. Enforcement and Violation Consequences

Non-compliant builds may be automatically blocked. Security may require rollback, hotfix, feature disablement, or emergency access revocation. Repeated bypass of security gates, concealment of vulnerabilities, deliberate introduction of backdoors, or unauthorized disabling of scanners may lead to disciplinary action up to termination and supplier contractual remedies.

Where a violation creates active risk, protective action may occur before disciplinary or contractual review is complete. Enforcement decisions will consider intent, recurrence, severity, impact, legal duties, and whether the individual promptly reported the issue and cooperated with remediation.

9. Exceptions and Risk Acceptance

SSDLC exceptions MUST identify the control, system, risk rating, business justification, mitigation, remediation plan, owner, approval, and expiration. Exceptions do not transfer accountability to Security and MUST be re-approved if the scope, architecture, or risk changes.

An exception MUST NOT be interpreted as permanent policy change. The control owner may require additional monitoring, narrower scope, remediation milestones, or earlier review. Expired exceptions automatically cease to authorize the deviation.

10. Standards and Regulatory Alignment

This policy is designed to support the enterprise ISMS and cybersecurity risk program. Mappings are implementation aids; they do not replace a formal applicability analysis, legal advice, or the authoritative standards and regulations.

Framework	Policy alignment
ISO/IEC 27001:2022	Supports secure development lifecycle, security requirements, architecture, secure coding, testing, change management, vulnerability management, logging, and separation of environments.
NIST CSF 2.0	GV.PO policy; ID.RA risk; PR.PS platform/software security; PR.DS data protection; DE.CM monitoring; RS.AN analysis; RC.IM improvements.
GDPR	Articles 25 and 32 apply where software processes personal data; design decisions should implement data minimization, access control, resilience, and appropriate security.

Authoritative reference set

- ISO/IEC 27001:2022, Information security, cybersecurity and privacy protection - Information security management systems - Requirements. This policy supports the ISMS risk-management model and applicable Annex A controls without reproducing proprietary standard text.
- NIST Cybersecurity Framework (CSF) 2.0, NIST CSWP 29 (2024). Control outcomes are organized across GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, and RECOVER as applicable.
- Regulation (EU) 2016/679 (General Data Protection Regulation, GDPR), including the principles of Article 5 and, where applicable, Articles 6, 25, 28, 30, 32, 33, 34, 35, and Chapter V on international transfers.

11. Review, Maintenance, and Approval

The policy owner MUST review this document at least annually and whenever a material incident, audit finding, law/regulation, technology change, threat development, merger/acquisition, or operating-model change may affect its adequacy. Proposed changes MUST be version-controlled and approved through the enterprise policy governance process. Local procedures may impose stricter requirements but MUST NOT weaken this policy without an approved exception.

End of controlled document.